

Narrativa Explicativa QQM+PRAGMATIC — La Ciencia de Medir lo que Importa

Por qué no basta con tener indicadores: el arte de que sean buenos

Versión 1.0 · Documento (c) del Kit QQM+PRAGMATIC CSCRM

"Dime cómo mides algo y te diré cómo se comportará el sistema que lo contiene."

— Adaptación del principio de Goodhart

I. El Problema de las Métricas que No Miden

Hay una escena que se repite en los Comités de Dirección de las organizaciones españolas con una regularidad que debería preocupar más de lo que preocupa: el CISO presenta una diapositiva con 47 métricas de ciberseguridad. Todas en verde. El CEO asiente. El Consejo aprueba el presupuesto. Y tres meses después, la organización descubre que llevaba 254 días comprometida a través de un proveedor que aparecía en el tablero de indicadores como "gestionado".

El problema no es la ausencia de métricas. El problema es la abundancia de métricas que no miden lo que dicen medir, que no predicen lo que pretenden anticipar, y que no generan ninguna acción cuando cambian. Es decir: métricas que son, en el sentido más preciso del término, decorativas.

El marco **QQM+PRAGMATIC** nació exactamente para resolver este problema.

II. QQM: La Disciplina de Derivar, No de Inventar

El método QQM (*Goal-Question-Metric*) tiene una premisa radical en su sencillez: ninguna métrica debe existir si no responde a una pregunta, y ninguna pregunta debe formularse si no operacionaliza un objetivo.

Basili y Rombach formularon el QQM en 1988 en el contexto de la ingeniería del software. El SEI de Carnegie Mellon ha desarrollado la variante **GQIM** (*Goal-Question-Indicator-Metric*) que añade una capa de indicadores entre las preguntas y los datos técnicos — exactamente lo que se necesita para operacionalizar objetivos nacionales de ciberseguridad en datos medibles por una organización individual.

En el contexto CSCRM español, los **cuatro objetivos QQM nacionales** se derivan de la Estrategia Nacional de Ciberseguridad, el Plan de Choque INCIBE 2025 y el Anteproyecto de Ley de Coordinación y Gobernanza de la Ciberseguridad:

- O1 — Reducir los incidentes con origen en la cadena de suministro (22,5% de las brechas; coste medio 4,33 M€)
- O2 — Aumentar la madurez CSCRm hasta L3 mínimo (IGM estimado España ~2,1; objetivo 3,0)
- O3 — Garantizar la visibilidad n-tier en infraestructuras críticas (80% sin evaluación de subcontratistas)
- O4 — Habilitar la respuesta coordinada nacional a incidentes CSCRm (~30% con PRI que incluye CS)

III. PRAGMATIC: La Disciplina de Exigirle Calidad a lo que se Mide

Krag Brotby y Gary Hinson desarrollaron el marco PRAGMATIC en *PRAGMATIC Security Metrics* (CRC Press, 2013) como respuesta a un problema sistemático: las organizaciones adoptaban métricas de ciberseguridad sin preguntarse si esas métricas eran realmente útiles.

Los nueve criterios del acrónimo PRAGMATIC capturan dimensiones específicas de utilidad:

- Predictivo — anticipa resultados futuros; útil antes del evento, no como obituario
- Relevante — conectada con los objetivos comprometidos; alguien decide algo con este dato
- Accionable — genera acciones concretas cuando cambia; no solo informa
- Genuino — mide lo que dice medir; resistente al gaming; no mejora solo con trucos de presentación
- Significativo — comprensible para la audiencia objetivo; el CEO lo entiende sin traducción técnica
- Preciso — datos fiables, fuentes verificables, error conocido; los datos inexactos generan falsa confianza
- Oportuno — disponible cuando se necesita para la decisión; la latencia puede ser más peligrosa que la ausencia
- Independiente — verificable por terceros sin conflicto de interés; la autodeclaración incentiva la subestimación
- Rentable — coste de producción proporcional al valor generado; medir tiene coste de oportunidad

IV. Los Hallazgos Principales

Fortaleza estructural: todos los indicadores obtienen puntuación máxima (9) en el criterio

Relevante. No hay métricas decorativas en el conjunto: todas responden a una pregunta que alguien necesita respondida.

La brecha más preocupante: el criterio **Independiente** tiene la media más baja (6,6). La dependencia de la autodeclaración es gestionable con triangulación (datos CCN-CERT/INCIBE, auditorías externas, certificaciones ENS/ISO 27001) pero debe reconocerse explícitamente.

Los indicadores estrella: cuatro indicadores obtienen ≥ 75 puntos: M20 (78), M09/M14/M18 (75 cada uno). Tres de los cuatro son indicadores de proceso verificable — contractuales, de plazos, de ciclo de vida — difícilmente manipulables.

Los indicadores con mayor potencial de mejora: M03, M04 (impacto económico) y M15 (ISACs) obtienen las puntuaciones más bajas, principalmente por problemas de oportunidad y precisión. La

mejora requiere fuentes alternativas: datos de seguros cibernéticos, registros CCN-CERT, datos de ISACs sectoriales.

V. El Valor de la Independencia: La Corrupción de las Métricas

Andrew Jaquith denominó *la ilusión del cumplimiento* al fenómeno por el que el sistema de métricas se convierte en el objetivo en lugar de en el instrumento. Las organizaciones aprenden a optimizar para el indicador en lugar de para el comportamiento que el indicador pretende medir.

En el contexto CSCRМ, la versión más frecuente es el inventario de proveedores que crece hasta cubrir el 100% del umbral requerido porque el proceso de alta es sencillo, mientras que el proceso de evaluación de riesgo queda como pendiente crónico. El ICIP (M06) marcará verde; la organización seguirá siendo vulnerable.

El remedio no es eliminar las métricas, sino diseñarlas para ser resistentes al gaming — que es exactamente lo que los criterios **Genuino** e **Independiente** de PRAGMATIC intentan verificar. Los contratos con cláusulas de ciberseguridad existen o no existen; los timestamps de notificación a CCN-CERT son verificables; el SBOM de un componente puede ser inspeccionado técnicamente.

VI. El Conjunto Mínimo Viable

Para organizaciones medianas sin equipos dedicados, el análisis PRAGMATIC ofrece el **Conjunto Mínimo Viable** de 8 indicadores que maximizan cobertura de objetivos con mayor calidad PRAGMATIC: ciclo de vida del proveedor, brecha por dominio, plazos NIS2, cláusulas contractuales, cobertura SBOM, IGM, MTTD-SC y PRI con módulo CS.

No son los ocho más fáciles de medir. Son los ocho que, medidos con rigor, dicen más sobre el riesgo real.

VII. La Paradoja de la Oportunidad

Las métricas más valiosas son con frecuencia las menos oportunas. El MTTD-SC es el indicador más relevante del conjunto y uno de los menos oportunos: se conoce con precisión solo después de análisis forense. El coste por incidente puede no ser definitivo hasta 18 meses después del evento.

La respuesta metodológica es combinar indicadores *leading* (predictivos, oportunos pero aproximados) e indicadores *lagging* (precisos pero retrasados). El conjunto de 20 indicadores CSCRМ está diseñado para cubrir ambos extremos. Juntos, ofrecen una visión completa. Solos, cualquiera de los dos grupos cuenta solo la mitad de la historia.

© 2026 · Narrativa Explicativa GQM+PRAGMATIC CSCRМ España · Documento (c)
Basili & Rombach (1988) IEEE TSE 14(6) · Brothby & Hinson (2013) CRC Press · Jaquith (2007) Addison-
Wesley · SEI CMU GQIM (2024) · NIST SP 800-55v2 dic. 2024